COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.3 · Vulnerability Remediation

Mestre CyberSec · **Aula 4.3 — Vulnerability Remediation** (8:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Remediação: patching (ideal); segmentation (isola); compensating control (quando patch impossível — virtual patch no firewall/IPS). MTTR (mean time to remediate): a métrica do time de vuln mgmt.

💡 Highlights que a prova CompTIA cobra

- Patching ideal; compensating: quando não dá patch (ICS legado)
- MTTR: tempo médio de remediação — a métrica do time

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'blocks the exploit without touching the vulnerable system'=virtual patch

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.3 — Vulnerability Remediation)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Remediação

Reparo ou remoção completa de uma vulnerabilidade de um sistema, geralmente aplicando um patch do fabricante; é a correção ideal e preferida na gestão de vulnerabilidades.

⚠️ ***Armadilha CompTIA:*** *Patching é sempre a solução IDEAL na prova; segmentação, compensating control e virtual patch são alternativas ('mitigation') quando o patch não é possível.*

• Correção (Gestão de Patches)

Processo formal de testar, agendar e implantar atualizações do fabricante que eliminam vulnerabilidades conhecidas em sistemas operacionais, aplicações e dispositivos.

⚠️ ***Armadilha CompTIA:*** *Se a questão pede a correção definitiva/permanente da falha, a resposta é patch; virtual patch e segmentação são paliativos e não corrigem o código.*

• Mitigação

Redução da probabilidade ou do impacto de uma vulnerabilidade sem eliminá-la — usando segmentação, controles compensatórios, patches virtuais ou exceções aceitas.

⚠️ ***Armadilha CompTIA:*** *Mitigação NÃO conserta a falha, apenas reduz o risco; remediação elimina. Se a questão diz 'cannot fix, reduce risk' = mitigar (4.3).*

• Segmentação

Isolamento de sistemas vulneráveis ou legados em segmentos de rede ou VLANs separados, impedindo que uma falha explorada alcance recursos críticos.

⚠️ ***Armadilha CompTIA:*** *Gatilho 'isolate' ou 'contains the compromise' sem remover a falha = segmentação; escolha típica para sistemas que não recebem patch.*

• Controle Compensatório

Controle alternativo aplicado quando o controle primário (o patch) não pode ser implantado, oferecendo redução de risco equivalente — ex.: ICS legado protegido por um IPS.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'device cannot be patched' / 'legacy ICS / SCADA' = compensating control. Não é remediação e não é exception (exception não adiciona controle).*

• **Patch Virtual**
Regra baseada em rede em firewall ou IPS que bloqueia tentativas de exploração de uma vulnerabilidade sem modificar ou reiniciar o sistema vulnerável.

⚠ ***Armadilha CompTIA:*** *'Blocks the exploit without touching the vulnerable system' = virtual patch. Não corrige o software; só impede a exploração pela rede — não marque como 'remediation'.*

• **Exceção (Exceção de Risco)**
Decisão documentada e aprovada pela gestão para deixar um sistema sem patch (geralmente legado) e aceitar o risco associado até que a remediação seja possível.

⚠ ***Armadilha CompTIA:*** *Exceção exige documentação e aprovação da gestão; o risco permanece. Distinção: compensating control ADICIONA um controle; exception apenas ACEITA o risco.*

• **Tempo Médio de Remediação (MTTR)**
Tempo médio decorrido entre a identificação de uma vulnerabilidade e sua remoção completa; é a métrica principal de desempenho do time de gestão de vulnerabilidades.

⚠ ***Armadilha CompTIA:*** *MTTR mede a velocidade de correção do time de vuln mgmt (menor = melhor). Não confundir com MTBF/MTTF (confiabilidade de hardware) nem MTTD (detecção).*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital usa uma estação de trabalho de ressonância magnética legada que executa um sistema operacional sem suporte. O fornecedor proíbe alterações no sistema operacional porque isso anularia o contrato de suporte, mas a estação precisa permanecer operacional para exames de pacientes. Qual estratégia de remediação MELHOR reduz o risco mantendo a funcionalidade exigida?

A) Colocar a estação em uma VLAN dedicada com ACLs de firewall restritas e monitoramento contínuo

B) Aplicar os patches mais recentes do sistema operacional fornecidos pelo fornecedor fora do horário comercial sem aprovação do fornecedor

C) Solicitar uma exceção de risco permanente e remover a estação da verificação de vulnerabilidades

D) Instalar um patch virtual diretamente no kernel do sistema operacional da estação

QUESTÃO 2 · CENÁRIO DE EXAME

Uma vulnerabilidade crítica em um servidor web voltado para a internet tem patch do fornecedor, mas a próxima janela de manutenção aprovada é em cinco dias. O monitoramento de segurança mostra tentativas ativas de exploração da vulnerabilidade. O IPS pode inspecionar e bloquear o tráfego de exploração. O que a equipe de segurança deve fazer PRIMEIRO?

A) Aguardar a janela de manutenção e aplicar o patch do fornecedor somente nesse momento

B) Implantar uma assinatura de patch virtual no IPS para bloquear o tráfego de exploração até que o servidor possa ser corrigido

C) Mover o servidor web para uma VLAN separada sem acesso à internet e deixá-lo assim permanentemente

D) Criar uma exceção de risco permanente porque o patch já está disponível

QUESTÃO 3 · CENÁRIO DE EXAME

O CISO quer uma métrica que mostre o tempo médio decorrido desde a descoberta de uma vulnerabilidade até sua remediação bem-sucedida. Qual métrica a equipe de gerenciamento de vulnerabilidades deve relatar?

A) Tempo médio para detecção (MTTD)

B) Tempo médio entre falhas (MTBF)

C) Tempo médio para remediação (MTTR)

D) Pontuação base do Common Vulnerability Scoring System (CVSS)

QUESTÃO 4 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades identifica patches de sistema operacional ausentes em 200 servidores de produção. A organização possui um sistema de gerenciamento de patches aprovado e uma janela de manutenção futura. Os patches foram testados e são suportados pelos fornecedores dos aplicativos. Qual é a MELHOR ação de remediação?

A) Implantar patches virtuais em todos os servidores e adiar indefinidamente a correção do sistema operacional

B) Segmentar cada servidor em sua própria VLAN em vez de aplicar os patches

C) Solicitar uma exceção de risco permanente para todos os 200 servidores para evitar impacto operacional

D) Implantar os patches aprovados por meio do sistema de gerenciamento de patches durante a janela de manutenção

QUESTÃO 5 · CENÁRIO DE EXAME

Um aplicativo crítico de negócios não pode ser executado em um sistema operacional corrigido, e o fornecedor não lançará uma atualização compatível por seis meses. A equipe de segurança implanta regras de WAF, restringe o acesso administrativo e aumenta o monitoramento do aplicativo. Qual termo MELHOR descreve essas ações?

A) Controles compensatórios

B) Gerenciamento de patches

C) Varredura de vulnerabilidades

D) Tempo médio para remediação

QUESTÃO 6 · CENÁRIO DE EXAME

Uma organização usa um controlador industrial embarcado que não pode ser corrigido porque o fabricante não fornece mais atualizações de firmware. A equipe de segurança coloca o controlador em um segmento de rede dedicado e permite apenas tráfego de gerenciamento específico por meio de um firewall. Qual estratégia de remediação está sendo usada?

A) Aplicação de patches

B) Segmentação

C) Patch virtual

D) Exceção de risco

QUESTÃO 7 · CENÁRIO DE EXAME

Uma vulnerabilidade de dia zero é anunciada para um dispositivo VPN voltado para a internet, e nenhum patch do fornecedor está disponível. A equipe de firewall cria uma assinatura que bloqueia o tráfego de exploração direcionado ao serviço VPN. Qual termo MELHOR descreve essa assinatura?

A) Atualização de firmware

B) Exceção de risco

C) Patch virtual

D) Varredura de vulnerabilidades

QUESTÃO 8 · CENÁRIO DE EXAME

Uma empresa decide manter um servidor de banco de dados sem patch online por um ano porque substituí-lo interromperia um sistema crítico de receita. O CISO assina um documento que reconhece o risco, lista controles compensatórios e define uma data de revisão. Como esse documento é chamado?

A) Plano de gerenciamento de patches

B) Política de segmentação

C) Plano de resposta a incidentes

D) Exceção de risco

QUESTÃO 9 · CENÁRIO DE EXAME

Um painel de gerenciamento de vulnerabilidades mostra quatro achados críticos que foram remediados em 4, 6, 8 e 10 dias. Qual é o tempo médio para remediação (MTTR)?

A) 7 dias

B) 4 dias

C) 6 dias

D) 10 dias

QUESTÃO 10 · CENÁRIO DE EXAME

Um fornecedor lança um patch crítico para um servidor web voltado para a internet, mas o patch ainda não foi testado com o aplicativo personalizado da organização. A próxima janela de manutenção está disponível. O que a equipe de gerenciamento de patches deve fazer PRIMEIRO?

A) Implantar o patch imediatamente em todos os servidores de produção sem testar

B) Testar o patch em um ambiente de homologação antes de implantá-lo em produção

C) Desativar permanentemente o aplicativo web até que o patch seja testado

D) Solicitar uma exceção de risco permanente e nunca aplicar o patch

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Colocar a estação em uma VLAN dedicada com ACLs de firewall restritas e monitoramento contínuo

A segmentação é a melhor estratégia de remediação quando um sistema não pode ser corrigido. Colocar a estação legada em uma VLAN dedicada com ACLs restritas e monitoramento limita o movimento lateral e reduz a exposição, preservando a funcionalidade clínica. Aplicar patches não aprovados pode violar o suporte do fornecedor, uma exceção permanente sem controles não é remediação, e patches virtuais normalmente são implantados em dispositivos de segurança de rede, não diretamente no kernel do SO sem suporte.

Questão 2: Alternativa B — Implantar uma assinatura de patch virtual no IPS para bloquear o tráfego de exploração até que o servidor possa ser corrigido

Um patch virtual no IPS é um controle compensatório que bloqueia o tráfego de exploração conhecido enquanto o patch agendado está pendente. Isso reduz o risco imediato sem esperar a janela de manutenção. Esperar deixa o servidor exposto, remover permanentemente o acesso à internet pode quebrar o serviço, e uma exceção de risco é inadequada quando existe patch e uma mitigação temporária está disponível.

Questão 3: Alternativa C — Tempo médio para remediação (MTTR)

O MTTR mede o tempo médio desde a descoberta da vulnerabilidade até a remediação e é a principal métrica de desempenho para SLAs de remediação no gerenciamento de vulnerabilidades. O MTTD mede o tempo de detecção, o MTBF mede a confiabilidade entre falhas, e o CVSS mede a severidade, não a duração da remediação.

Questão 4: Alternativa D — Implantar os patches aprovados por meio do sistema de gerenciamento de patches durante a janela de manutenção

A aplicação de patches é a remediação ideal quando os patches estão disponíveis, testados, suportados e podem ser implantados em uma janela aprovada. O sistema de gerenciamento de patches fornece implantação controlada. Patches virtuais, segmentação e exceções permanentes são menos apropriados porque a vulnerabilidade real pode ser corrigida com patches suportados.

Questão 5: Alternativa A — Controles compensatórios

Controles compensatórios são salvaguardas alternativas usadas quando a remediação ideal, como a aplicação de patches, não é possível. Regras de WAF, acesso administrativo restrito e monitoramento aprimorado reduzem o risco enquanto o aplicativo permanece no sistema sem patch. Gerenciamento de patches, varredura e MTTR não são os controles em si.

Questão 6: Alternativa B — Segmentação

A segmentação isola o controlador que não pode ser corrigido para que ele não se comunique amplamente com outros sistemas. Regras restritas de firewall limitam o tráfego apenas ao necessário. Isso reduz a exposição e limita o movimento lateral. A aplicação de patches não é possível, o patch virtual exigiria uma assinatura de IPS/WAF, e uma exceção de risco é um processo formal de aceitação, não o controle técnico descrito.

Questão 7: Alternativa C — Patch virtual

Um patch virtual é um controle compensatório implementado em um dispositivo de segurança, como firewall ou IPS, para bloquear a exploração de uma vulnerabilidade conhecida até que um patch real esteja disponível. Não é uma atualização de firmware, aceitação formal de risco ou varredura de vulnerabilidades.

Questão 8: Alternativa D — Exceção de risco

Uma exceção de risco é uma decisão formal de aceitar um risco conhecido, geralmente com controles compensatórios documentados, aprovações e data de expiração ou revisão. Ela é usada quando a remediação não é viável dentro do prazo exigido. Gerenciamento de patches, segmentação e resposta a incidentes não aceitam formalmente o risco residual.

Questão 9: Alternativa A — 7 dias

O MTTR é o tempo médio de remediação. Some os quatro tempos de remediação (4 + 6 + 8 + 10 = 28) e divida por quatro, o que equivale a 7 dias. As outras opções são valores individuais ou um cálculo incorreto.

Questão 10: Alternativa B — Testar o patch em um ambiente de homologação antes de implantá-lo em produção

A prática recomendada de gerenciamento de patches é testar os patches em um ambiente de homologação antes da implantação em produção, especialmente quando aplicativos críticos podem ser afetados. Isso equilibra segurança e

disponibilidade. A implantação imediata sem teste arrisca indisponibilidade, desativar permanentemente o aplicativo é excessivo, e uma exceção permanente é inadequada quando existe um patch.